COMPLIANCESPRINT

EU AI Act + SOC 2 + DPDP Readiness Gap Kit

7-day delivery · Plain language · Action-ready

PREPARED FOR: SKIT.AI

Prepared 26 October 2026 · ComplianceSprint · unadhi.com/compliancesprint/
WhatsApp: wa.me/9182163868 · Not legal advice · Not certification

1 · Your Gap Analysis

Skit.ai — EU AI Act Gap Analysis (Free Sample)

Company: Skit.ai (skit.ai)

Date: 20 October 2026

Type: AI Debt Collection Software

Customers: 120+ collection teams (banks, lenders, agencies)

Certifications: SOC 2, ISO 27001, PCI-DSS

What Skit.ai Does (from public site)

- **Collection Intelligence:** AI decisioning, journey design, and optimisation for debt collections
- **AI Agents:** Specialised voice AI agents coordinating decisions, conversations, and learning
- **Compliance:** Built-in FDCPA, TCPA, Reg F guardrails with litigation-ready audit trail
- **Responsible Voice AI:** Guardrails, bias controls, human oversight, agent cards
- **Enterprise security:** SOC 2, ISO 27001, PCI-DSS certified

---

Why EU AI Act Applies to Skit.ai

Skit.ai's AI agents make **autonomous decisions** about:

1. Who to contact and when (debtor selection and timing)

2. What to say during collection calls (conversation path decisions)

3. Escalation paths and payment negotiation parameters

Under the EU AI Act (fully enforced August 2026):

Criterion	Skit.ai Status	Risk
Annex III, pt.5(b): Creditworthiness assessment	Debt collection AI used by banks/lenders	**HIGH-RISK** — deployer obligations
Annex III, pt.5(a): Access to essential services	Collection decisions affect access to credit restructuring	**HIGH-RISK** — deployer obligations
Art.3(4): Deployer definition	Skit.ai's clients are deployers; Skit.ai is provider	Obligations cascade down
Art.26: Deployer obligations	Clients must conduct DPIA, human oversight, monitoring	Skit.ai must enable this

---

Gap Analysis vs. EU AI Act Requirements

Requirement	Skit.ai Status	Gap
Art.6 — High-risk classification rules	Not mentioned anywhere	**MISSING** — no risk classification framework
Art.9 — Risk management system	Responsible AI page exists but no Art.9-type risk register	**PARTIAL** — need formal risk mgmt documentation
Art.10 — Data governance	Not visible on public site	**MISSING** — no data governance statement
Art.11 — Technical documentation	Not visible	**MISSING** — no system architecture docs published
Art.12 — Record-keeping & logging	Audit trail claimed for compliance calls	**PARTIAL** — needs EU AI Act-specific logging spec
Art.13 — Transparency	Agent cards exist (per Responsible AI page)	**PARTIAL** — need deployer-facing transparency docs
Art.14 — Human oversight	Mentioned, not documented	**PARTIAL** — no formal oversight protocol
Art.15 — Accuracy, robustness	Not visible	**MISSING** — no accuracy benchmarks published
ISO 42001 (AI governance standard)	Not mentioned	**MISSING** — becoming de facto AI compliance cert
DPDP Act (India 2023) readiness	Not visible	**MISSING** — India HQ, must comply

---

Actionable Gaps (Top 5)

1. **No EU AI Act risk classification** — Skit.ai's AI agents fall under Annex III high-risk but there's no formal classification, no Art.9 risk register

2. **No Art.11 technical documentation** — Clients (banks) will demand system architecture, training data provenance, model cards for their own conformity assessments

3. **No ISO 42001** — SOC 2 + ISO 27001 + PCI-DSS is strong, but ISO 42001 is emerging as the AI-specific certification their enterprise clients will require

4. **No DPDP Act compliance posture** — As an India-headquartered company processing Indian customer data, the Digital Personal Data Protection Act 2023 applies and is not referenced

5. **Missing deployor toolkit** — Even if Skit.ai itself is compliant, their clients (banks, lenders) need deployer documentation (DPIA, human oversight logs, Art.26 compliance pack) that Skit.ai doesn't currently provide

---

Summary

Skit.ai has **strong compliance foundations** (SOC2, ISO27001, FDCPA/TCPA guardrails, audit trails) but is **unprepared for EU AI Act** enforcement that began August 2026. Their enterprise BFSI clients — especially those with EU operations or EU-resident debtors — will cascade conformity requirements down to Skit.ai as the AI provider. The biggest gaps are formal risk documentation, ISO 42001, and a deployer documentation kit for clients.

A free 1-page gap kit covering all 7 Art.9-15 requirements with a 1-week remediation roadmap is available on request.

2 · EU AI Act — What the Law Requires (full reference)

Article 6 — Risk Classification
Every AI feature must be classified into risk tiers (unacceptable / high-risk / limited / minimal). High-risk systems (Annex III: hiring, credit, education, essential services, law enforcement) carry the heaviest duties and must be registered in the EU database.

Article 9 — Risk Management
A documented, iterative risk-management system: identify, estimate and evaluate risks; mitigate; test continuously; keep a risk register. For high-risk systems this is mandatory, not optional.

Article 10 — Data Governance
Training/validation/test data must be relevant, representative, complete and free of bias where feasible; document data provenance, collection practices and processing operations.

Article 11 — Technical Documentation
System architecture, model design, training data, evaluation results and intended purpose must be documented (Annex IV structure) and kept up to date — clients ask for this before contracting.

Article 12 — Record-Keeping
Automatic logging of events over the system's lifetime to support post-market monitoring; logs must match the system's intended purpose.

Article 13 — Transparency
Users must be told they are interacting with AI; deployers must receive clear instructions of use; synthetic content must be labelled.

Article 14 — Human Oversight
Systems must be designed for meaningful oversight: humans can understand output, intervene, override or stop the system.

Article 15 — Accuracy & Robustness
Appropriate accuracy, robustness and cybersecurity levels disclosed up front; error rates benchmarked and maintained.

3 · SOC 2 — Trust Services Criteria (enterprise buyers ask)

Control Environment (CC1)
Integrity and ethical values: code of conduct, governance structure, board oversight, org structure with defined responsibilities.

Risk Assessment (CC3)
Risk identification across objectives, change management, fraud considerations and IT infrastructure.

Information & Communication (CC2)
Internal and external communication of control responsibilities; incident reporting paths; user training.

Monitoring Activities (CC4)
Ongoing and separate evaluations of controls, including third-party delivery providers.

Information System & General IT (CC6-9)
Logical and physical access (CC6), system operations (CC7), change management (CC8), and risk mitigation for technology (CC9) — the technical backbone auditors examine.

Availability (A1)
Backups, recovery procedures, capacity planning and disaster-recovery testing align with availability commitments.

Confidentiality & Privacy (C1/CC)
Encryption at rest/in transit, data classification, retention and disposal align with contractual and regulatory commitments.

4 · India DPDP Act — Domestic Obligations

Data Principal Rights
Consent must be free, specific, informed, unconditional and unambiguous; a verifiable mechanism for withdrawal; rights to access, correction, erasure and grievance redress.

Data Fiduciary Obligations
Purpose limitation, data minimisation, storage limitation, reasonable security safeguards and breach notification to the Board and affected principals.

Consent Manager & Records
Maintain the Register of Consents, lawful-basis mapping, and data-processing records as required under the DPDP Rules 2025.

Cross-Border Transfers
Transfer of personal data outside India only to notified countries/territories — map your data flows and document the legal basis.

Children's Data & Significant Fiduciaries
Parental consent flows for children's data; additional obligations if classified as a Significant Data Fiduciary (incl. Data Protection Impact Assessment).

DPIA & Audit
Data Protection Impact Assessment for high-risk processing and annual data-audit obligations apply to significant fiduciaries.

5 · Compliance Checklist (15 items)

- ☐ Classify every AI feature into an EU AI Act risk tier (template: Annex I)
- ☐ Readiness score computed (0-100) with per-article breakdown
- ☐ Risk register started (Art. 9) — owner + due date per risk
- ☐ Data governance statement drafted (Art. 10)
- ☐ Technical documentation outline drafted (Art. 11 structure)
- ☐ Logging spec defined (Art. 12)
- ☐ Transparency/user-notice copy drafted (Art. 13)
- ☐ Human oversight protocol defined (Art. 14)
- ☐ Accuracy benchmarks baseline recorded (Art. 15)
- ☐ ISO 42001 readiness self-check filled
- ☐ SOC 2 trust-services criteria mapped (CC1-CC9, A1, C1)
- ☐ DPDP consent-flow + register mapped
- ☐ Cross-border data-flow map drawn
- ☐ EU authorised representative appointed (if serving EU market)
- ☐ 30-day action plan with owners written

6 · 30-Day Action Plan

Week 1	**Inventory + classification** List all AI features, classify risk tiers, compute readiness score (<60% = act now).
Week 2	**Documentation pack draft** Risk register, data governance, technical documentation outline (Art. 9-11).
Week 3	**Oversight + transparency** Human oversight protocol, user notices, logging spec (Art. 12-14).
Week 4	**SOC 2 + DPDP alignment** Map controls, consent flows, cross-border data map, audit dry-run.

ComplianceSprint — EU AI Act + SOC 2 + DPDP readiness gap kits for Indian SaaS. ₹4,999 one-time · Partners earn 50% (₹2,499/sale) · 7-day delivery · Free 1-page sample first.
unadhi.com/compliancesprint/ · wa.me/9182163868